

Informe GDPR.

El RGPD no trae un “Excel oficial” con KPIs de ciberseguridad, pero desde 2025 se ha ido consolidando de facto un cuadro de indicadores: lo marcan las guías europeas, los reguladores, las normas ISO y, muy especialmente, las sanciones y brechas publicadas.¹²³⁴

1. Punto de partida: riesgo, no fetichismo de controles

El RGPD es, en esencia, una norma de gestión de **riesgo** sobre derechos fundamentales, no un catálogo de firewalls. La doctrina reciente habla explícitamente de “enfoque basado en el riesgo” como forma de regulación, donde las medidas de seguridad (art. 32) se calibran según probabilidad y gravedad del impacto sobre las personas, sin abandonar el enfoque clásico de derechos.⁵

Traducido a métricas, esto implica que todo indicador serio tiene que pivotar sobre tres ejes: nivel de riesgo residual, eficacia de las salvaguardas y evidencia de cumplimiento (o de su ausencia, vía brechas y sanciones).⁶⁷

2. Bloque 1: indicadores de incidentes, brechas y sanciones

A nivel europeo, 2025 se ha consolidado como el año en que se disparan las notificaciones de brechas: más de 400 incidentes diarios de media en la UE, con un aumento aproximado del 22% frente al año anterior, según estudios sobre notificaciones GDPR. Las multas totales por RGPD rondan ya los miles de millones de euros acumulados desde 2018, con estudios que cifran el acumulado en torno a varios miles de millones a comienzos de 2025, lo que ha convertido a la sanción económica en un indicador duro y comparable de cumplimiento.⁸⁹

1 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

2 <https://www.audidat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

3 https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

4 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

5 <https://privacymatters.dlapiper.com/2025/06/spain-spanish-data-protection-authority-publishes-annual-report/>

6 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

7 <https://www.audidat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

8 https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

9 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

En España, la AEPD ha convertido su Memoria anual en un verdadero cuadro de mando: en 2024 impone unos 35,5–35,6 millones de euros en sanciones, un 19% más que el año previo, con 281 multas y un protagonismo claro de las brechas de datos, que concentran aproximadamente el 37% del importe sancionador (30 procedimientos, unos 13,1 millones de euros). Eso, leído como CISO, son métricas de resultado puro: número de reclamaciones, número de procedimientos, importe total y porcentaje atribuible a fallos de seguridad.¹⁰¹¹

En paralelo, el EDPB, con su compendio de decisiones sobre seguridad del tratamiento y notificación de brechas (artículos 32, 33 y 34), está fijando, caso a caso, lo que se considera un nivel adecuado de diligencia: tiempos de detección, plazos de notificación, robustez de cifrado, calidad de la segmentación, etc. De ahí emergen indicadores indirectos: tiempo medio hasta la detección, tiempo de notificación a la autoridad y a los afectados, y proporción de brechas en las que las medidas técnicas atenúan efectivamente el impacto.¹²

Tabla: algunos indicadores “duros” que ya se usan

Dimensión	UE (tendencia)	España (AEPD)
Notificaciones de brecha	>400 diarias de media en 2025, +22% interanual 5	Peso creciente en expedientes y sanciones 13
Importe anual de multas	En torno a 1,2 mil millones €/año UE-27 56	~35,5–35,6 M€ en 2024, +19% vs. 2023 13
Peso de brechas en las multas	Importante en muchos países 56	37% del importe sancionador en 2024 3
Casos transfronterizos (OSS)	Decisiones crecientes sobre seguridad y brechas 4	370 procedimientos de cooperación en 2024 1

3. Bloque 2: indicadores de capacidad y madurez (GDPR + NIS2 + ISO)

Desde 2025, NIS2 se ha convertido en el hermano mayor musculoso que obliga a concretar en indicadores lo que RGPD formula en clave jurídico-principial. ENISA ha publicado guías técnicas sobre cumplimiento de NIS2, donde desgrana medidas obligatorias de gestión de riesgos de ciberseguridad y los roles y competencias mínimos en entidades esenciales e importantes.¹³¹⁴

Aunque NIS2 no es RGPD, los mismos sistemas, procesos y personas soportan ambos marcos; por eso ENISA aterriza la abstracción “medidas técnicas y organizativas apropiadas” en prácticas medibles: gestión de vulnerabilidades, continuidad de negocio, formación del personal, supervisión continua,

¹⁰ <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

¹¹ <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

¹² <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

¹³ <https://dig.watch/updates/gdpr-violations-rise-europe-2025>

¹⁴ <https://www.audiat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

segmentación, cifrado robusto, autenticación multifactor. La consecuencia práctica es que cada vez más supervisores nacionales utilizan indicadores de NIS2 como proxy de seguridad RGPD: porcentaje de activos cubiertos por monitorización, tiempo median de parcheo, número de sistemas críticos sin MFA, cobertura de cifrado en reposo y en tránsito.¹⁵¹⁶

En paralelo, las normas ISO 27001 e ISO 27701, usadas masivamente como pruebas de “accountability” RGPD, obligan a formalizar métricas de riesgo: identificación de amenazas, clasificación de activos, niveles de impacto (alto, medio, bajo), probabilidad, y valor de riesgo calculado como producto impacto × probabilidad. La propia lógica de PIAs y DPIAs exigida por RGPD se apoya en este enfoque, obligando a documentar y, por tanto, a poder medir cuántos tratamientos tienen EIPD, cuántos riesgos residuales “altos” quedan y qué porcentaje de ellos dispone de planes de mitigación.¹⁷

4. Bloque 3: indicadores operativos de ciberseguridad alineados con RGPD

Si miramos el pulso de la industria en 2025–2026, se ha consolidado un consenso bastante claro sobre qué medir para demostrar que se protege el dato personal con algo más que juramentos en un comité. Se generalizan métricas como:¹⁸¹⁹

- eficacia de prevención de pérdida de datos (ratio de incidentes bloqueados frente a intentos totales, medido en sistemas DLP);
- indicadores de preparación y gobierno (porcentaje de políticas cumplidas, grado de implantación de requisitos de GRC, puntuaciones de “security rating” externas);
- métricas de monitorización e incidentes (número de eventos significativos detectados, tiempo medio de respuesta, tiempo de contención, niveles de severidad).¹¹¹⁰

Estas métricas no nacen del RGPD, pero encajan perfectamente con los artículos 24 y 32: demuestran que el responsable no solo declara medidas, sino que puede mostrar su efectividad y adecuación al riesgo. El énfasis creciente en análisis impulsados por IA para detectar patrones de amenaza y evaluar madurez de controles hace que la propia métrica se vuelva dinámica: ya no importa solo cuántos incidentes se cierran, sino cuántos se predijeron y evitaron con base en señales débiles.²⁰²¹²²

¹⁵ <https://dataprivacymanager.net/5-biggest-gdpr-fines-so-far-2020/>

¹⁶ <https://dig.watch/updates/gdpr-violations-rise-europe-2025>

¹⁷ <https://www.audidat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

¹⁸ <https://privacymatters.dlapiper.com/2025/06/spain-spanish-data-protection-authority-publishes-annual-report/>

¹⁹ https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

²⁰ <https://privacymatters.dlapiper.com/2025/06/spain-spanish-data-protection-authority-publishes-annual-report/>

²¹ <https://dig.watch/updates/gdpr-violations-rise-europe-2025>

²² <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

5. Bloque 4: indicadores nacionales en España y comparación global

En el caso español, los indicadores públicos se concentran en el output del sistema de protección de datos: reclamaciones, procedimientos, sanciones, ámbitos sectoriales (plataformas de internet, telecomunicaciones, empleo) y tipología de infracciones (falta de transparencia, marketing ilícito, vigilancia desproporcionada, brechas). La Memoria 2024 de la AEPD, por ejemplo, recoge 18.855 reclamaciones, una reducción del 13% respecto a 2023, pero con un peso creciente de las brechas y de los casos de alta complejidad tecnológica (IA, espacios de datos, neurodatos), que exigen precisamente mejores métricas de seguridad.²³²⁴

Comparativamente, otros reguladores europeos publican indicadores similares –número de brechas notificadas, volumen de multas, distribución sectorial–, y estudios paneuropeos muestran que países con grandes plataformas tecnológicas alojadas (Irlanda, por ejemplo) concentran volúmenes sancionadores mucho mayores, superando varios miles de millones de euros acumulados. España, con un tejido más distribuido de PYMEs y administraciones, presenta importes mucho más modestos, pero una densidad alta de casos en sectores regulados como telecomunicaciones y servicios digitales. En cualquier caso, la tendencia global es clara: subida de notificaciones, estabilización de la cuantía anual de sanciones en torno a cifras muy elevadas y ampliación del foco desde “Big Tech” hacia finanzas, salud y energía.²⁵²⁶²⁷²⁸

En el plano mundial, fuera del ecosistema RGPD, los indicadores inspirados en la norma europea se reutilizan en marcos de privacidad y seguridad de otras jurisdicciones, mientras las estadísticas globales de brechas en 2025–2026 confirman aumento de frecuencia y costes, con patrones cambiantes de ataque que presionan para refinar métricas de impacto, tiempos de respuesta y resiliencia. La idea de “convergencia regulatoria” hacia un conjunto de métricas mínimas –brechas, multas, tiempos de notificación, madurez de controles– está bastante asentada en informes internacionales de ciberseguridad.²⁹³⁰

23 <https://dataprivacymanager.net/5-biggest-gdpr-fines-so-far-2020/>

24 https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

25 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

26 <https://privacymatters.dlapiper.com/2025/08/eu-enisa-guidelines-on-compliance-with-nis-2-directive-published/>

27 https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

28 <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

29 <https://www.twobirds.com/en/insights/2025/eu-cybersecurity--enisa-publishes-final-nis2-guidance>

30 https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

6. Bloque 5: hacia un cuadro de mando GDPR para España

Si uno quisiera, desde España, construir un cuadro de mando nacional de indicadores RGPD de ciberseguridad comparable internacionalmente, tendría que beber de estas fuentes: datos de la AEPD (reclamaciones, brechas, sanciones, cooperación transfronteriza), guías y decisiones del EDPB sobre seguridad y brechas, métricas de madurez de NIS2 (vía ENISA) y taxonomías ISO 27001/27701 para riesgo e impacto. El resultado sería un panel que combine indicadores de resultado (brechas, sanciones, reclamaciones), de proceso (porcentaje de tratamientos con EIPD, tiempos medios de notificación, cobertura de cifrado, uso de MFA) y de capacidad (formación, recursos asignados, roles y competencias alineados con NIS2).³¹³²³³³⁴³⁵³⁶³⁷

La ironía, por supuesto, es que el RGPD, que vive obsesionado con la minimización, necesita ahora que midamos casi todo para demostrar que minimizamos algo. La buena noticia es que la convergencia entre derecho, ingeniería y gestión del riesgo va generando un lenguaje común donde un regulador español puede entenderse con un CISO en Singapur o Toronto a base de tasas de brechas, tiempos de respuesta y curvas de riesgo residual.³⁸³⁹⁴⁰

131415

³¹ <https://kioscert.com/blog/iso-27001-27701-kvkgdpr-mapping-guide>

³² <https://www.audidat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

³³ https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

³⁴ <https://securityscorecard.com/resources/learning-center/9-cybersecurity-metrics-kpis-to-track/>

³⁵ <https://privacymatters.dlapiper.com/2025/06/spain-spanish-data-protection-authority-publishes-annual-report/>

³⁶ <https://academic.oup.com/idpl/article-abstract/14/2/169/7674907>

³⁷ <https://www.thoropass.com/blog/cybersecurity-kpis>

³⁸ https://www.edpb.europa.eu/news/news/2024/edpb-publishes-oss-case-digest-security-processing-and-data-breach-notification_en

³⁹ <https://www.audidat.com/blog/noticias/memoria-aepd-2024-reclamaciones-sanciones-retos-ia/>

⁴⁰ <https://deepstrike.io/blog/data-breach-statistics-2025>